Lo que falta fuera del código

Equipo 3. Cumplimiento en GCP. 28 de octubre de 2026.

Líder: Pedro Alejandro Rodríguez González (@Pedroxls).

El repositorio ya tiene el gate, el catálogo, la red, el bootstrap, el drift, la evidencia y el agente. Nada de eso se aplica solo. Esta lista es lo que hay que crear en una consola, con una cuenta que acepte términos y tenga facturación.

En este orden

1. Proyecto dev y facturación
Dónde: console.cloud.google.com, proyecto nuevo, luego Billing.
Anotar: project_id y billing_account (forma 000000-000000-000000).
El monto del presupuesto (budget_amount_usd) espera el número de créditos del curso, pregunta P-13.
Desbloquea HU-07. Sin esto no se aplica nada.

2. APIs
Dónde: APIs y servicios. Service Usage tiene que estar activa antes de que Terraform encienda el resto.
Lista: Compute, IAM, Resource Manager, Service Usage, Storage, Pub/Sub, Cloud Run, BigQuery, Logging, Cloud Asset, AI Platform (Vertex), Secret Manager, Billing Budgets, Artifact Registry, Cloud Scheduler e IAM Credentials.

3. Identidad del pipeline, sin llaves JSON
Se crea al aplicar infra/bootstrap. No se descarga ninguna llave.
Pegar en GitHub, Settings, Variables: GCP_WIF_PROVIDER (salida gcp_wif_provider), GCP_PLAN_SA (salida gcp_plan_sa) y GCP_PROJECT_ID.
Desbloquea el plan real de dev en cada pull request.

4. Presupuesto
Lo crea el mismo bootstrap, con alertas al 50, 90 y 100 por ciento hacia Pub/Sub.
Hay que definir budget_amount_usd al aplicar. El freno que destruiría ambientes sigue apagado (enable_cost_killswitch = false).

5. Protección de main
Dónde: GitHub, Settings, Branches, en Pedroxls/Comunicaciones-Avanzadas.
Exigir 1 aprobación y los checks estatico, politicas, secretos y cumplimiento.
Variable opcional MODO_POLITICAS. Si no existe, el modo es bloqueo. advertencia reporta y no bloquea.

6. Personas
Pedro ya es el dueño por defecto (@Pedroxls).
Faltan los usuarios reales de Diego (políticas) y Paulo (agente y workflow) en .github/CODEOWNERS. Hoy siguen como @USUARIO_GITHUB_DIEGO y @USUARIO_GITHUB_PAULO.
En GCP, las listas de miembros salen vacías hasta tener los correos, en forma user:correo.

7. Infracost
Dónde: infracost.io, una API key. Secreto de GitHub: INFRACOST_API_KEY.
Si no está, el workflow avisa y sigue. No bloquea el merge.

8. Slack
Dónde: api.slack.com, una app y un canal del equipo.
Bot token y signing secret van a Secret Manager, no al repositorio.
La URL de interactividad se pega cuando Cloud Run del agente tenga dirección. Los botones de aprobar y rechazar (HU-09) son posteriores al MVP.

9. Vertex AI / Gemini
Dónde: Vertex AI, habilitar la API y revisar la cuota (riesgo R-07).
Si hay cuota y se instala google-adk, el proceso usa USE_VERTEX=1. Si no hay cuota o el paquete no está, el

agente responde con la plantilla y el veredicto de las políticas no cambia.
No hace falta una llave en el repo: la cuenta del agente es la del servicio.

10. Looker Studio

Dónde: lookerstudio.google.com, con la cuenta de Google de cumplimiento.
Conectar el dataset BigQuery cumplimiento. Las vistas reporte_por_marco y hallazgos_abiertos ya están en Terraform.
El PDF del reporte se exporta desde Looker. No se publica desde el repositorio.

11. Estado remoto

El bucket con versionado se crea al aplicar infra/bootstrap.
Después se puede descomentar el backend en infra/environments/dev/versions.tf. Hasta entonces el estado es local y no se sube.

12. Candado de la evidencia

No activarlo en dev. lock_evidence_retention está en false. Pasarlo a true es irreversible (R-06).
La cadena de hashes funciona igual sin el candado. La retención del diseño (pregunta P-12) todavía no está confirmada por el socio formador.

Qué deja el código apagado a propósito

enable_cloud_run crea Cloud Run, Artifact Registry y el job de drift. Las imágenes por defecto son de demostración; hay que sustituirlas por las del agente, la evidencia y el drift.

enable_drift_sink crea el sink de Audit Logs hacia Pub/Sub. El permiso para que el sink publique solo se crea junto con el sink.

enable_cost_killswitch crea el servicio del freno. Aunque se encienda, el código se niega a destruir recursos.

manage_default_network borra la red default del proyecto y exige gcloud. Un plan normal no la toca.

lock_evidence_retention es el candado irreversible del bucket.

Qué se corrigió para que el apply no falle

La suscripción de cumplimiento-eventos manda los reintentos agotados a una cola de fallidos. Pub/Sub rechaza esa cola si su cuenta de servicio no puede publicar ahí y leer la suscripción. Esos dos permisos ya están en el Terraform.

El horario del drift apuntaba a la API vieja de Cloud Run. Ahora usa la URL v2 del job y, cuando el job exista, la cuenta de drift puede invocarlo.

Si el sink de Audit Logs se enciende, su identidad de escritor recibe permiso de publicar en el tema. Si la cuenta que publica el presupuesto no es la esperada, se cambia la variable budget_publisher sin reescribir el recurso.

Qué el código todavía no hace

La evidencia de las pruebas vive en memoria del proceso. Escribir en el bucket de Cloud Storage exige el bucket real y credenciales. El candado sigue apagado.

El agente cita control, severidad y recurso con una plantilla. Gemini entra solo con cuota de Vertex, el paquete google-adk y USE_VERTEX=1. Si Vertex falla, la plantilla responde y el merge lo sigue decidiendo OPA.

Slack, Looker Studio, la protección de main y los usuarios de Diego y Paulo no tienen una API que este repositorio pueda completar sin esas cuentas.

Qué pegar de vuelta

Variables de GitHub: GCP_PROJECT_ID, GCP_WIF_PROVIDER y GCP_PLAN_SA. Opcionales: MODO_POLITICAS y AGENTE_URL.

Secreto: INFRACOST_API_KEY. El token de Slack va a Secret Manager, no a GitHub.

No crear llaves JSON de cuentas de servicio. No subir un terraform.tfvars con el proyecto real. El ejemplo está

en infra/bootstrap/terraform.tfvars.example.